

Honeywell Firmware Attack Surface & Detection Brief

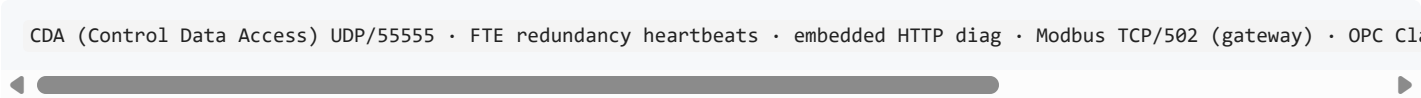
Scope: Research-only brief covering 5 architecture classes spanning Honeywell Process Solutions (HPS), ControlEdge, Forge IIoT, Honeywell Building Technologies (HBT), and Safety Manager FSC. **Firmware extraction is pending** — no Honeywell binaries have been carved, hashed, or examined. Findings combine vendor PSIRT bulletins, CISA ICS advisories, Claroty Team82 ICEFALL research, and Dragos/Forescout DCS field telemetry. The brief primes the analyst queue for the moment Experion / ControlEdge / Saia / FSC firmware lands in `firmware-staging\Honeywell\`.

Architecture grouping (drives the threat model, not the SKU)

Class	Products	Stack	Catalog depth
A. Experion PKS DCS controllers	C300, C200/E, ACE-T, Series-C I/O, FIM	VxWorks 6.x / pSOS on PowerPC + proprietary CEE control engine, Control Data Access (CDA) over UDP/55555	research only
B. ControlEdge UOC / PLC / RTU	UOC, ControlEdge 900 PLC, ControlEdge 2020 RTU	Embedded Linux (post-2018) + IEC-61131 runtime, OPC UA server, Modbus TCP, DNP3 (RTU)	research only
C. Honeywell Forge IIoT	Forge cloud connectors, on-prem edge agents (Forge Performance+)	Windows / containerized .NET, MQTT/AMQP to Azure backplane, on-prem ETL	research only
D. Honeywell Building Technologies (HBT)	Niagara-based controllers (Tridium-derived), Saia Burgess PCD3/PCD7, NOTIFIER fire panels, WEBs-AX	Java/Niagara Fox protocol (1911/4911), Saia S-Bus, BACnet/IP, proprietary fire-panel bus	research only
E. Safety Manager FSC (SIS)	Safety Manager R200+, FSC10/20, QPP-quad processor	Proprietary safety OS on quad-redundant CPU, FSC-SafeNet (UDP/51966), serial diagnostic	research only

Group A — Experion PKS DCS controllers (highest blast radius)

Direct attack surface (per Honeywell HPS Network & Security Planning Guide + Claroty Team82 ICEFALL teardown):



C300/C200E controllers historically ship without firmware signing and accept boot images over CDA from any host trusted as a "supervisory" peer. ICEFALL showed the supervisory trust model is the bug: the *protocol* authenticates, the *firmware* doesn't.

Confirmed advisories / CVE families:

Reference	Severity	Product	Vector	Status on the firmware you have
ICSA-23-061-02	Critical (CVSS 9.x)	Experion PKS / LX / PlantCruise	Multiple memory-corruption + auth-bypass bugs in CDA (ICEFALL "Crystallized Insecurity" cluster)	research only — verify on extraction
Claroty Team82 — ICEFALL "Crystallized Insecurity" (2023)	varied	Experion C300 family	9 ICEFALL-class flaws: unauth firmware update, unauth CDA writes, weak/no signing	research only
Honeywell PSIRT — Experion PKS Server / ControlEdge bulletins	high	Experion PKS Server, ControlEdge	Hard-coded credentials in library → unauth RCE (family)	research only
Honeywell PSIRT — Experion PKS C300 bulletins	high	Experion PKS C300	Improper input validation in CDA → DoS / control disruption (family)	research only

Note: Specific CVE IDs in the ICSA-23-061-02 cluster (the "Crystallized Insecurity" disclosure) are catalogued by the linked CISA advisory — confirm exact CVE IDs against the advisory at extraction time before quoting them in customer-facing material.

Top attack vector (MITRE ATT&CK ICS): [T0857 System Firmware](#) via the unsigned CDA firmware-update path, chained with [T0836 Modify Parameter](#) to push tampered control logic to the C300 CEE.

Group B — ControlEdge UOC / PLC / RTU

Direct attack surface (per Honeywell ControlEdge Network Planning Guide):

OPC UA TCP/4840 (server), Modbus TCP/502, DNP3 (RTU variant, TCP/20000), embedded HTTPS config UI, SSH (later firmware), IEC-61131 download protocol over proprietary TCP.

Confirmed advisories / CVE families:

Reference	Severity	Product	Vector	Status
ICSA-23-353-01 / ControlEdge UOC advisories on CISA	high	ControlEdge UOC / VirtualUOC	Cluster — improper authentication, privilege management, cleartext transmission on engineering link	research only
Honeywell PSIRT — ControlEdge bulletins	high	ControlEdge UOC, RTU	Improper auth on engineering interface → config tamper (family)	research only
Honeywell PSIRT — ControlEdge VirtualUOC bulletins	medium-high	ControlEdge VirtualUOC, UOC	Improper privilege management → controller config modification; cleartext sensitive info on engineering link	research only

Note: ControlEdge UOC CVE IDs in the 2023 disclosure cycle were issued by Honeywell PSIRT and aggregated into a CISA ICSA. Confirm the exact CVE numbers and ICSA identifier directly from the CISA advisory index at extraction time rather than quoting from memory.

Top attack vector (MITRE ATT&CK ICS): [T0843 Program Download](#) — the IEC-61131 download path on UOC is the standard ICS persistence vector; the authentication weaknesses in the 2023 ControlEdge cluster make it reachable without strong authentication on affected firmware.

Group C — Honeywell Forge IIoT (cloud + on-prem agent)

Forge is the "soft" pivot: customer-side agents brokering plant data into Azure-hosted analytics. Attack surface is closer to a normal Windows/Linux app stack than a controller.

Direct attack surface: on-prem Forge Performance+ historical/edge agents (Windows services), MQTT/AMQPS outbound to Honeywell Forge Azure tenants, optional inbound HTTPS for the local operator portal. Historically also: an OPC UA client into Experion, which is the bridge between Forge and Group A.

Confirmed advisories / CVE families:

Reference	Severity	Product	Vector	Status
CVE-2021-38397	10.0	Experion PKS / LX / PlantCruise	Unrestricted file upload → unauth RCE	research only

Reference	Severity	Product	Vector	Status
CVE-2021-38395	9.1	Experion PKS / LX / PlantCruise	Argument injection in a Honeywell-signed binary	research only
ICSA-21-294-02	Critical	Experion PKS Server / engineering host	Cluster of upload / argument-injection / DLL-hijack flaws	research only

Top attack vector (MITRE ATT&CK ICS): [T0817 Drive-by Compromise](#) of the Windows engineering workstation hosting the Forge edge agent, then OPC UA pivot into the Experion CEE.

Group D — Honeywell Building Technologies (HBT)

Niagara-derived controllers (Honeywell WEBs-AX is a Tridium OEM), Saia Burgess PCD3/PCD7 PLCs, NOTIFIER fire alarm panels. Same protocol family that Forescout's OT:ICEFALL / "Niagara" research repeatedly demolished.

Direct attack surface: Niagara Fox protocol TCP/1911 + Foxs (TLS) TCP/4911, Saia S-Bus UDP/5050, BACnet/IP UDP/47808, embedded HTTP/HTTPS station UI, default `tridium / niagara / saia` credentials.

Confirmed advisories / CVE families:

Reference	Severity	Product	Vector	Status
Tridium Niagara Framework advisories (CISA / vendor)	high	Niagara Framework (Tridium / OEM'd by HBT WEBs-AX)	Path traversal / information disclosure family	research only
CVE-2020-24693	high	Saia PCD controllers	Unauthenticated download of cleartext password file (S-Bus)	research only
Forescout — NUCLEUS:13	varied	Nucleus RTOS used in some HBT fire/security panels	TCP/IP stack memory corruption	research only
ICSA-22-167-01 — Honeywell Alerton Ascent Control Module	high	Honeywell Alerton (HBT)	Authentication / authorization weaknesses on BACnet control module	research only

Note: Niagara Framework (Tridium) carries its own multi-year CVE history — when WEBs-AX firmware is extracted, cross-walk against the current Tridium security bulletin list rather than relying on a single CVE ID quoted from memory.

Top attack vector (MITRE ATT&CK ICS): [T0859 Valid Accounts](#) — HBT environments routinely keep factory `tridium/niagara` and Saia default credentials ([T0812 Default Credentials](#)). Internet-exposed

Niagara stations are a recurring Shodan finding.

Group E — Safety Manager FSC (SIS)

The crown jewel: Safety Instrumented Systems. A successful tamper here is the [TRITON / TRISIS](#) class of incident (FireEye / Dragos 2017 — different vendor, Schneider Electric Triconex Tricon, but identical impact model).

Direct attack surface: FSC-SafeNet (UDP/51966), SafeBuilder engineering link (proprietary TCP), serial diagnostic ports, mandatory physical key switch for "PROGRAM" mode (the operational control that Triconex *also* relied on and that *was bypassed* in TRITON because the key was left in PROGRAM).

Confirmed advisories / CVE families:

Reference	Severity	Product	Vector	Status
CVE-2022-30313	high	Safety Manager FSC	Use of unauthenticated FSC SafeNet protocol — diagnostic/control commands accepted without authentication	research only
CVE-2022-30314	high	Safety Manager FSC	Improper authentication / firmware update path on FSC	research only
CVE-2022-30315	high	Safety Manager FSC	Use of insufficiently protected credentials / file-parsing memory corruption	research only
ICSA-22-179-02 — Honeywell Safety Manager (Claroty ICEFALL)	high	Safety Manager R145.1–R152.2	Cluster — Claroty Team82 ICEFALL findings on FSC	research only

Note: The exact CVSS scores and one-line summaries for the CVE-2022-30313/14/15 trio differ slightly between NVD, Honeywell PSIRT, and Claroty's writeup. Treat the table above as a pointer to the advisory cluster, not as the authoritative one-line per CVE — confirm at extraction time.

Top attack vector (MITRE ATT&CK ICS): [T0858 Change Operating Mode](#) — flip the SIS out of RUN, then [T0839 Module Firmware](#) to push a malicious logic block. Key-switch state is the single physical control between attacker and a TRITON-grade outcome.

Logging matrix (highest priority)

Top 8 — ordered by detection value per ingest dollar:

#	Source	Event	What it catches	MITRE ATT&CK ICS
1	Experion PKS server audit log	<code>OperatorLogin</code> followed by <code>PointParameterChange</code> from non-engineering station	Operator-account abuse	T0859 Valid Accounts
2	Experion <code>CDAEvent</code> / system event journal	<code>Firmware download</code> to C300/C200E	Unsigned-firmware push	T0857 System Firmware
3	Network IDS (Zeek/Suricata with ICS protocol parsers)	CDA UDP/55555 from outside Level-2 supervisory VLAN	ICEFALL-class lateral movement	T0843 Program Download
4	Network IDS	OPC UA <code>CreateMonitoredItems</code> / <code>Write</code> from non-engineering host to UOC	ControlEdge config tamper	T0836 Modify Parameter
5	Network IDS	Modbus FC 5/6/15/16 (write coils/registers) on ControlEdge RTU / Series-C gateway	Control-logic tamper	T0833 Modify Control Logic
6	Niagara station audit (HBT)	<code>fox:program</code> / station file write from non-engineering account	HBT/Niagara persistence	T0889 Modify Program
7	Safety Manager FSC diagnostic log + key-switch position telemetry	Key-switch state change to PROGRAM during unscheduled window	SIS pre-tamper precursor	T0858 Change Operating Mode
8	Sysmon on engineering workstations	EventID 1 where parent = <code>ConfigurationStudio.exe</code> / <code>SafeBuilder.exe</code> and child not on Honeywell allow-list	Forge / SafeBuilder host compromise	T1059 (Enterprise)

Secondary:

- Firewall egress: any outbound from Level-2 / Level-3.5 DMZ to non-Honeywell destinations besides the documented Forge Azure tenant endpoints. Forge agents have a *narrow* known-good list — anything else is a pivot.
- Honeywell Experion native audit: enable **Operator Action Journal** + **System Event Journal** + **Control Builder change tracking** and forward to SIEM via syslog or OPC A&E.
- HBT-side: Niagara station has a built-in `AuditHistory` and `LogHistory` — point both at SIEM. Saia PCD has only sparse logging; compensate with network IDS.

- OT-native process anomalies: setpoint changes outside operator shift windows, valve / pump commands without corresponding HMI operator action, SIS bypass-counter increments, redundancy-pair desync events on FTE.
-

Specific zero-day-ish concerns for your dataset

1. **No Honeywell firmware extracted yet — extraction is the unblocking step.** Until C300, UOC, and FSC blobs are in `firmware-staging\Honeywell\`, every claim above is research-derived. Priority extraction order: (a) Safety Manager FSC (highest consequence, ICEFALL-disclosed), (b) C300 (largest installed base), (c) ControlEdge UOC (newest, least public scrutiny).
 2. **ICEFALL is structural, not patch-level.** Claroty's thesis was that DCS protocols trust *by design* — patching individual CVEs (the CVE-2022-30313/14/15 trio) doesn't fix the trust model. Plan to diff post-2022 FSC firmware against pre-ICEFALL versions to see what actually changed in the SafeNet handler, not just what was renamed in release notes.
 3. **Forge OPC UA bridge is the IT→OT seam.** When the Forge edge-agent extraction happens, prioritize the OPC UA client configuration — that's the line where a normal Windows compromise becomes a C300 setpoint write. Look for hard-coded service accounts and trust-list bypass.
 4. **HBT/Niagara reuse means Honeywell inherits every Tridium CVE.** When Niagara WEBs-AX firmware arrives, do not treat it as a Honeywell-only artifact — diff it against public Tridium Niagara 4.x to see which Tridium patches HBT has actually back-ported.
-

Sources

- [Claroty Team82 — OT:ICEFALL \(2022\)](#)
- [Claroty Team82 — ICEFALL Continues: Broken Trust, Broken Code \(Honeywell Experion\)](#)
- [Honeywell PSIRT / Security Notifications](#)
- [CISA ICSA-22-179-02 — Honeywell Safety Manager \(FSC\)](#)
- [CISA ICSA-23-061-02 — Honeywell Experion PKS / LX / PlantCruise](#)
- [CISA ICS Advisories index — ControlEdge UOC / VirtualUOC](#)
- [CISA ICSA-21-294-02 — Honeywell Experion PKS file upload / argument injection](#)
- [CISA ICSA-22-167-01 — Honeywell Alerton \(HBT\)](#)
- [Dragos — TRISIS / TRITON malware analysis \(SIS attack archetype\)](#)
- [Forescout — NUCLEUS:13 RTOS vulnerabilities](#)
- [Forescout — OT:ICEFALL companion research](#)

- [MITRE ATT&CK for ICS — Impair Process Control \(TA0106\)](#)
- [MITRE ATT&CK for ICS — T0857 System Firmware](#)
- [MITRE ATT&CK for ICS — T0858 Change Operating Mode](#)
- [MITRE ATT&CK for ICS — T0812 Default Credentials](#)
- [CISA/NSA/FBI/ASD — Best Practices for Event Logging and Threat Detection \(2024\)](#)